UNIVERSIDAD CES · BASES DE DATOS

Análisis y matriz de trazabilidad

Problema, alcance, actores, requisitos, reglas y supuestos · Requisito → entidad → endpoint → prueba

---

Proyecto final: Gestión de objetos perdidos

Juan Alejandro Chaux Perdomo · Noviembre de 2026

1. Documento de análisis

Problema

En las sedes de la Universidad CES (Poblado y Sabaneta) se encuentran objetos que alguien entrega en una oficina. Hoy no hay un registro único que diga qué se recibió, quién lo entregó, dónde se guarda, quién lo reclamó y a quién se devolvió. El sistema debe **recibir, identificar, custodiar, consultar y devolver** esos objetos sin borrar nunca información y dejando historial de cada cambio.

Alcance (obligatorio según el enunciado)

- Registro, login, recuperación de contraseña y control de acceso por roles.
- Catálogos de sedes, bloques, dependencias, categorías y tipos de objeto (crecen desde la aplicación).
- Recepción de objetos con responsables, ubicación de hallazgo, custodia y de 1 a 5 fotografías.
- Consulta con filtros, edición controlada, inactivación y reactivación con trazabilidad.
- Reclamación, devolución única con constancia PDF, inventario con exportación PDF, historial y auditoría.
- Dashboard del administrador.
- Colección de Postman por módulos.

Fuera de alcance: el control de ingreso y salida de personas (AccessEvent) es una ampliación opcional y no se implementó.

Actores y roles

Actor	Descripción
ADMIN	Administra usuarios y catálogos, recibe y devuelve, corrige con motivo, inactiva y reactiva, consulta auditoría, exporta y ve el dashboard.
OPERADOR	Consulta catálogos, crea tipos de objeto, recibe y edita objetos disponibles, registra reclamaciones y devoluciones, inactiva errores con motivo y exporta.
CONSULTA	Consulta el inventario activo con una proyección reducida (sin datos personales, ubicaciones ni fotos). No modifica nada.
Persona (sin cuenta)	Estudiante, empleado, contratista, proveedor o visitante que **entrega** o **reclama** un objeto. Se registra en `persons`.

El registro público siempre crea cuentas CONSULTA. Un ADMIN promueve a OPERADOR. El primer ADMIN lo crea el seed.

Requisitos funcionales

Código	Requisito	Dónde se cumple
RF01	Sedes: crear, consultar, filtrar, editar, inactivar y reactivar; nombre único normalizado.	`campus_*`, UNIQUE `uq_campuses_normalized_name`
RF02	Bloques asociados a una sede, nombre único en la sede; un bloque de otra sede se rechaza.	`block_*`, UNIQUE (campus_id, normalized_name), validación en recepción

Código	Requisito	Dónde se cumple
RF03	Dependencias y categorías con selección desde listas activas.	`department_*`, `object_category_*`
RF04	Tipos de objeto con buscador, creación desde el formulario y prevención de duplicados.	`object_type_*`, modal del frontend, UNIQUE (category_id, normalized_name)
RF05	Persona que entrega: identificación, nombre, vinculación, dependencia, contacto opcional.	`person_*`
RF06	Cada objeto físico con tipo, descripción, hallazgo, custodia, responsables y fotos.	`POST /object-lost` (multipart)
RF07	Listados paginados, detalle y filtros combinables; mensaje sin resultados.	`GET /object-lost` (getByFilter)
RF08	Editar disponibles con motivo; valores anteriores en auditoría.	`PATCH /object-lost/{id} + audit_logs`
RF09	Inactivar sin borrar (motivo, fecha, responsable); solo ADMIN reactiva.	`/inactivate`, `/reactivate`
RF10	Agregar e inactivar fotos conservando archivo y metadata; mínimo una foto activa.	`object_photo_*`
RF11	Reclamaciones y una sola devolución con constancia.	`claim_*`, `return_*`
RF12	Inventario, indicadores y PDF con los filtros aplicados.	`inventory_*`, `dashboard_*`
RF13	Cuentas, roles, estado, perfil y contraseña; auditoría con permisos.	`auth_*`, `user_*`, `audit_*`

Reglas de negocio

1. **Nada se borra.** No hay rutas DELETE; las FK son `ON DELETE RESTRICT`; triggers de la base rechazan DELETE/TRUNCATE en todas las tablas y UPDATE en `audit_logs` y `return_records`.
2. **`is_active` y `status` son ejes distintos.** `status` = situación física (DISPONIBLE/DEVUELTO); `is_active` = validez del registro. Un DEVUELTO sigue activo como histórico.
3. Un registro inactivo no se edita, no recibe fotos ni se devuelve. Reactivar exige ADMIN, motivo y referencias válidas; conserva el estado.
4. Un DEVUELTO no admite edición ordinaria ni inactivación; solo **corrección administrativa** (ADMIN, motivo) que no toca propietario, devolución ni estado.
5. No se aceptan referencias inexistentes ni catálogos inactivos para nuevos registros (400). Un catálogo inactivo sigue visible en los registros históricos.
6. No se inactiva una sede con bloques activos ni un catálogo del que dependan objetos activos DISPONIBLES (409 con explicación).
7. Fecha de hallazgo: no futura y no posterior a la recepción. Se guarda en UTC y se muestra en hora de Bogotá.
8. Fotos: 1 a 5 activas, JPEG o PNG verificados por contenido, máximo 5 MB, nombre interno generado, archivo en almacenamiento controlado y servido solo por ruta autorizada.
9. Recepción atómica: si falla una foto no queda recepción parcial (rollback + compensación de archivos temporales).
10. Edición con **bloqueo optimista** (`version`): versión desactualizada → 409.
11. Devolución: exige objeto activo DISPONIBLE y reclamación ACEPTADA de ese objeto; transacción con `SELECT … FOR UPDATE` + UNIQUE en `return_records.object_lost_id` y `claim_id`. Una segunda devolución → 409.

12. A lo sumo una reclamación ACEPTADA por objeto (índice único parcial).
13. Cambios de estado y su auditoría se guardan en la **misma transacción**.
14. JWT de 30 minutos; logout revoca el `jti`; cambiar/restablecer contraseña o inactivar incrementa `token_version`; el rol se lee de la base en cada petición.
15. Recuperación: mismo mensaje exista o no el correo; token aleatorio guardado como hash, 15 minutos, un solo uso; al usarlo se revocan los demás pendientes.
16. ADMIN no puede inactivar ni degradar al último administrador activo.

Estados

```
Objeto:        DISPONIBLE ──(devolución)──> DEVUELTO        (irreversible)
Registro:      activo <──(inactivar / reactivar ADMIN)──> inactivo   (solo si DISPONIBLE)
Reclamación:   PENDIENTE ──> ACEPTADA | RECHAZADA           (una decisión, con motivo)
```

Supuestos y decisiones propias (confirmar con el docente)

#	Supuesto
S1	Las rutas del dashboard (`/dashboard/summary`, `/by-category`, `/by-campus`, `/recent`) son propuesta nuestra: el PDF pide el dashboard pero no define sus rutas.
S2	Normalización de nombres: sin tildes ni diéresis, minúsculas y espacios colapsados; **la ñ se conserva** («año» ≠ «ano»).
S3	Mecanismo de recepción en la devolución: **confirmación digital** (`owner_confirmation = true`) más constancia PDF generada por el sistema.
S4	CONSULTA no ve descripción, ubicaciones precisas, bloque, personas ni fotos (pueden exponer datos personales); ve código, tipo, categoría, sede, fecha y estado.
S5	«Operaciones pendientes» de una persona = reclamaciones PENDIENTES o ACEPTADAS sin devolución.
S6	Para aceptar una reclamación debe estar registrada la verificación de identidad (`identity_verified`).
S7	Los catálogos inactivos no se editan (primero se reactivan). Inactivar y reactivar siempre exige motivo (mínimo 5 caracteres).
S8	Las fotos de un objeto DEVUELTO o inactivo no se modifican.
S9	El correo de recuperación usa un **buzón local** (archivos `.eml` en `backend/instance/outbox`) por defecto; SMTP real es configurable en `.env`.
S10	El código del objeto es `OBJ-` + id con 6 dígitos; si una recepción falla, ese número no se reutiliza (puede haber saltos).

Matriz de trazabilidad

Requisito → entidad → endpoint → prueba

RF	Entidades	Endpoints (`/api`)	Casos	Evidencia automática
RF01 Sedes	Campus	`GET/POST /campuses`, `GET/PATCH /campuses/{id}`, `PATCH …/inactivate`, `…/reactivate`	PA05, PA21	pytest `test_pa05_*`, `test_catalog_unique_normalized_name`, `test_pa21_inactivation_blocked_by_dependencies`; Postman `05 Campus`
RF02 Bloques	Block, Campus	`GET/POST /blocks`, `GET/PATCH /blocks/{id}`, `…/inactivate`, `…/reactivate`	PA05, PA06	`test_pa06_filter_blocks_by_campus`, `test_block_reactivation_requires_active_campus`; Postman `06 Blocks`
RF03 Dependencias y categorías	Department, ObjectCategory	`/departments…`, `/object-categories…` (6 rutas cada uno)	PA21	`test_only_admin_sees_inactive_catalogs`, `test_reason_required_for_inactivation`; Postman `07`, `08`
RF04 Tipos	ObjectType	`/object-types…` (6 rutas; POST para OPERADOR/ADMIN)	PA07, PA21	`test_pa07_create_type_from_form_and_duplicates`, `test_pa21_inactive_catalog_stays_in_history`; Postman `09 ObjectTypes`; e2e «tipo creado en el modal»
RF05 Persona que entrega	Person, Department	`/persons…` (6 rutas)	—	`test_persons_crud_and_permissions`, `test_person_inactivation_blocked_with_pending_claim`; Postman `10 Persons`
RF06 Recepción	ObjectLost, ObjectPhoto, AuditLog	`POST /object-lost` (multipart)	PA08, PA09, PA10	`test_pa08_*`, `test_pa09_*`, `test_pa10_*`, `test_reception_accepts_png_and_missing_fields`; Postman `11 ObjectLost`
RF07 Consulta	ObjectLost (+ joins)	`GET /object-lost`, `GET /object-lost/{id}`	PA15, PA19	`test_pa15_*`, `test_pa19_*`, `test_pagination_validation`; Postman `11 ObjectLost`
RF08 Edición	ObjectLost, AuditLog	`PATCH /object-lost/{id}`, `PATCH …/administrative-correction`	PA11, PA24	`test_pa11_*`, `test_edit_rejects_not_editable_fields`, `test_pa24_*`
RF09 Inactivar/reactivar	ObjectLost, AuditLog	`PATCH …/inactivate`, `…/reactivate`	PA12, PA13	`test_pa12_pa13_inactivate_and_reactivate`

RF	Entidades	Endpoints (`/api`)	Casos	Evidencia automática
RF10 Fotos	ObjectPhoto	`GET/POST /object-lost/{id}/photos`, `GET /object-photos/{id}/file`, `PATCH …/inactivate`, `…/reactivate`	PA14	`test_pa14_*`, `test_add_photos_respects_maximum`; Postman `12 ObjectPhotos`
RF11 Reclamación y devolución	Claim, ReturnRecord	`/claims…` (7 rutas), `/returns…` (4 rutas)	PA16, PA17	`test_pa16_*`, `test_claim_rules`, `test_database_partial_unique_index_blocks_second_accepted`, `test_pa17_*`; Postman `13`, `14`; `postman/prueba_concurrencia.py`
RF12 Inventario e indicadores	ObjectLost	`GET /inventory`, `/inventory/summary`, `/inventory/export`, `/dashboard/*`	PA18, PA20	`test_pa18_*`, `test_pa20_*`, `test_inventory_summary_and_validations`, `test_dashboard_admin_only_and_consistent`; Postman `15`, `17`
RF13 Cuentas y auditoría	User, Role, PasswordResetToken, TokenRevocation, AuditLog	`/auth/*` (7 rutas), `/users…` (5), `/roles`, `/audit-logs`, `/object-lost/{id}/history`	PA01–PA04, PA23	`test_auth.py` (15 pruebas), `test_audit_logs_admin_only`; Postman `01`–`04`, `16`

Casos de aceptación del PDF (§9)

Caso	pytest	Postman (carpeta / request)	Navegador (e2e)
PA01 registro, duplicados, rol ignorado	`test_pa01_register_assigns_consulta_and_ignores_role`, `test_pa01_register_rejects_duplicates`	01 Login: «rol ADMIN enviado no eleva privilegios», duplicados → 409	Registro exitoso
PA02 login y errores	`test_pa02_login_ok_and_errors`, `test_pa02_inactive_user_cannot_login`	01 Login / Validaciones; 03 Users «usuario inactivo → 403»	Login erróneo
PA03 logout, cambio y reset invalidan sesiones	`test_pa03_logout_revokes_token`, `test_pa03_change_password_invalidates_sessions`, `test_pa04_forgot_and_reset_password`	01 Login «token revocado → 401»; 02 Password «token anterior al cambio → 401»	—
PA04 recuperación igual para correo existente o no; token de un uso	`test_pa04_forgot_and_reset_password`, `test_pa04_expired_reset_token_fails`, `test_reset_revokes_other_pending_tokens`	02 Password (mismo mensaje; token inválido → 400)	Mensaje genérico
PA05 tercera sede y bloque	`test_pa05_new_campus_and_block_visible_in_selector`	05 Campus «tercera sede»; 06 Blocks	Crear sede

Caso	pytest	Postman (carpeta / request)	Navegador (e2e)
PA06 bloques por sede; bloque ajeno/inexistente/inactivo	`test_pa06_filter_blocks_by_campus`, `test_pa06_rejects_foreign_missing_or_inactive_block`	06 Blocks; 11 ObjectLost / Validaciones (3 requests)	Lista dependiente
PA07 tipo desde el formulario, duplicado, categoría inexistente	`test_pa07_create_type_from_form_and_duplicates`	09 ObjectTypes	Modal «Crear tipo»
PA08 objeto con dos fotos, código, quien entrega y operador del JWT	`test_pa08_reception_with_two_photos`	11 ObjectLost «recepción con 2 fotos (PA08)»	Recepción completa
PA09 sin fotos, ejecutable, >5 MB, >5 fotos, fecha futura	`test_pa09_rejects_invalid_receptions`	11 ObjectLost / Validaciones (5 requests con `postman/fotos`)	—
PA10 fallo de archivo sin recepción parcial	`test_pa10_storage_failure_leaves_no_partial_reception`	11 ObjectLost «fallo de archivo simulado» + «inventario no muestra…» (requiere `ALLOW_FAULT_INJECTION=true`)	—
PA11 edición con motivo, antes/después, versión vieja → 409	`test_pa11_edit_with_reason_history_and_version`	11 ObjectLost «editar con motivo», «versión desactualizada»; 16 Audit «history»	Edición + historial
PA12 inactivar conserva en base y auditoría; sale del inventario	`test_pa12_pa13_inactivate_and_reactivate`	11 ObjectLost «inactivate», «inactivo sigue en la base»	—
PA13 ADMIN reactiva; operador no; operaciones sobre inactivo	`test_pa12_pa13_inactivate_and_reactivate`	11 ObjectLost «reactivate como ADMIN», «como OPERADOR → 403»	—
PA14 foto inactiva conserva archivo; última foto → 409	`test_pa14_photo_inactivation_keeps_file_and_last_photo`	12 ObjectPhotos	Inactivar foto
PA15 filtros combinados, límites del día, paginación, sin resultados	`test_pa15_combined_filters_day_limits_and_pagination`	11 ObjectLost «filtros combinados», «paginación», «sin resultados»	—
PA16 rechazada conserva DISPONIBLE; aceptada → devolución y constancia	`test_pa16_rejected_claim_keeps_object_available`, `test_pa16_accepted_claim_allows_return_with_receipt`	13 Claims; 14 Returns «constancia PDF»	Reclamación, devolución y PDF
PA17 dos devoluciones concurrentes	`test_pa17_concurrent_returns_only_one_succeeds` (8 hilos)	`postman/prueba_concurrencia.py` (script adicional)	—
PA18 inventario excluye devueltos e inactivos	`test_pa18_inventory_excludes_returned_and_inactive`	15 Inventory	Inventario
PA19 CONSULTA no modifica ni ve datos privados	`test_pa19_consulta_reduced_projection_and_no_changes`	Permisos en todas las carpetas; 11 ObjectLost «como CONSULTA»	Vista CONSULTA

Caso	pytest	Postman (carpeta / request)	Navegador (e2e)
PA20 PDF con filtros y fecha; coincide con la consulta	`test_pa20_export_pdf_matches_inventory_query`	15 Inventory «export … mismo total»	Exportar PDF
PA21 catálogos históricos; bloqueo de inactivación	`test_pa21_inactivation_blocked_by_dependencies`, `test_pa21_inactive_catalog_stays_in_history`	05 Campus «con bloques activos → 409»	—
PA22 no hay DELETE; la base no borra	`test_pa22_no_delete_routes_and_database_blocks_delete`, `test_delete_method_not_allowed`	— (no existen rutas DELETE)	DBeaver (guion paso 15)
PA23 último administrador	`test_pa23_last_admin_protection`	03 Users «degradar al último ADMIN → 409», «a sí mismo → 409»	—
PA24 corrección administrativa de un devuelto	`test_pa24_administrative_correction_of_returned`	14 Returns «administrative-correction DEVUELTO», «como OPERADOR → 403»	OPERADOR no ve el botón